



SECURITY & DATA PROTECTION OVERVIEW

Your Data, Protected.

Safeguarding-first, by design.

FA verification with the minimum data.

Your information, deletable on demand.

Aligned with UK GDPR & the DPA 2018.



Protection, by the numbers

A few figures that capture how we treat your data.

3 fields

are all that we share with the FA to verify a referee — name, FA number, county

0 card numbers

stored on our servers — all card data is handled by Stripe (PCI DSS)

100%

of application tables protected by database Row-Level Security

Data Protection at a Glance

Whistle Connect connects grassroots coaches with qualified, FA-registered referees — including young officials. We are the **data controller** for the personal data we hold and we process it under the UK General Data Protection Regulation (UK GDPR) and the Data Protection Act 2018.

THE PRINCIPLES WE BUILD TO

- **Data minimisation** — we collect and share only what a task needs, nothing more.
- **Least privilege** — access is enforced at the database, scoped to each user and role.
- **Safeguarding first** — protections for under-18 referees are enforced in code, not just policy.
- **Security in transit** — all traffic is encrypted over HTTPS; payments never touch our servers.

This document explains, in plain English, what we collect, how we verify referees with the FA, how we keep your money and messages safe, and how you can delete your data at any time.

What We Collect — and Why

We collect personal data only when you register, build a profile, make or accept bookings, or message another user. Each category below has a specific operational purpose.

Account & Contact

Name, email and any phone number you choose to provide.

Role & Referee Detail

Coach, referee or admin; plus qualification level, county and DBS status.

Date of Birth & Age

For referees, to apply age-eligibility and safeguarding rules.

Postcode & Area

Geocoded to an approximate location to match nearby matches. No real-time tracking.

Payment Information

Handled by Stripe. We hold transaction and wallet records, not full card numbers.

In-App Messages

The content of messages between confirmed coaches and referees.

Device & Push Tokens

Web-push subscriptions and notification tokens used to deliver alerts.

Error & Diagnostic Logs

IP, device and error data captured to keep the service secure and reliable.

Date of birth and any data relating to under-18 referees are treated as sensitive and handled under our safeguarding rules (page 06). Data is held in our managed Postgres database (Supabase); payment data lives with Stripe.

Purpose-limited

No precise location

No card numbers

No advertising trackers

Identity, Authentication & Access

Who can see what is decided by the database, not just the screen. Even a mistake in the interface cannot reveal one user's data to another, because access rules are enforced one layer deeper.

Secure Sign-In

Authentication is managed by Supabase Auth with encrypted, cookie-based sessions and automatic token validation.

Row-Level Security

Every application table enforces per-user access policies in the database, so users only ever read and write their own rows.

Role-Based Access

Coach, referee and admin each see a scoped view. Admin tools are gated to verified administrators only.

Hardened Functions

Privileged database functions run with a pinned, safe search path and have anonymous execution revoked.

Least-Privilege Service Role

The all-access service key is used only by trusted system jobs (cron, webhooks), never exposed to the browser.

Encrypted Transport

All traffic is served over HTTPS. Secrets and keys live in server-side configuration, never in client code.

Defence in depth: a coach can never load another coach's bookings, and a referee can never read a thread they aren't part of — the database refuses the query, regardless of what the app asks for.

Database-enforced

Per-user isolation

Role scoping

HTTPS everywhere

Verifying Referees with the FA

Every referee's FA registration number is checked with their County FA before coaches rely on it. The exchange is deliberately narrow and fully auditable.

- 1 **Referee submits FA number** at sign-up. It is format-checked (8–10 digits) and must be unique. Status: *Pending*.
- 2 **An administrator queues a verification request**, generating a single-use secure token.
- 3 **The correct County FA is emailed** — routed by county from a maintained directory of 40+ County FAs.
- 4 **The FA clicks Confirm or Not Found** — one tap on a secure token link. No login, no account, no portal.
- 5 **The result syncs back** — the referee's status updates, referee and admins are notified, and the request is archived.

✓ Shared with the FA

Referee name FA number County

✗ Never shared

Date of birth Contact details Location
Payment data Messages

WHAT THE COUNTY FA RECEIVES

WHISTLE CONNECT

FA Number Verification Request

Please confirm whether the following FA registration number is valid and currently active.

REFeree NAME	A. Williams
FA NUMBER	1 0 2 9 3 8 4 7
COUNTY FA	Hampshire

✓ Confirm

✗ Not Found

One click — no login or account required.

Only three fields ever leave our system. The link is single-use and tied to one request, so it cannot be reused or guessed.

Safeguarding by Design

Referees on the platform may be aged 14 to 17. Protecting them is not left to good intentions — the rules are enforced in the system itself.

- **Minimum age 14.** Under-14s cannot register; date of birth is captured and validated at sign-up.
- **Age-appropriate matching.** Eligibility is calculated for the actual match date, so referees are only offered fixtures suitable for their age.
- **Parental consent for under-16s.** The account is **locked** until a parent or guardian verifies consent via a one-click email.
- **The lock is in the database.** It is set by a server-side trigger at account creation, so no sign-up path can bypass it.
- **No direct messaging for under-16s.** In-app chat is disabled; coaches are directed to email a parent or guardian for match updates.
- **Credentials tracked.** DBS clearance and safeguarding status are recorded and monitored by administrators.



ENFORCED IN CODE

Locked • Consent-gated • Age-matched

There is no code path that lets an unverified under-16 account take bookings or message adults. Safeguarding is the default state, not a setting someone has to remember to switch on.

Payments, Handled Safely

Money moves through the platform when coaches top up a wallet, funds are held in escrow for a booking, and referees are paid out. Every step is designed so that money is never lost, double-charged or stranded.

Stripe Handles Cards

Card details are entered with Stripe, a PCI-DSS Level 1 provider. Full card numbers never reach our servers.

Escrow Protection

A coach's payment is held in escrow and only released to the referee once the match is confirmed complete.

No Double Charges

Every payment instruction carries an idempotency key, so a retry can never charge or pay twice.

Safe Withdrawals

Referee payouts use an audited multi-step process, so funds can never be debited without the transfer completing.

Verified Webhooks

Payment events from Stripe are cryptographically signature-checked and de-duplicated before they are trusted.

Weekly Reconciliation

An automated job checks balances and flags any stuck funds for administrators every week.

The financial ledger is immutable and retained even after an account is deleted — protecting both parties and meeting UK money-movement and audit obligations.

PCI DSS via Stripe

Idempotent writes

Escrow held funds

Audited payouts

Delete Your Data, Anytime

You can delete your account yourself from inside the app — **Profile > Delete account** — meeting Apple App Store and Google Play requirements. Deletion erases your personal data while preserving the financial records the law requires us to keep.

What we erase / anonymise

- Name, phone and avatar
- Postcode and approximate location
- Date of birth
- FA registration number
- Sign-in is disabled and the email is released

What we retain (and why)

- Transaction, payout and escrow records
- Dispute history
- Kept only as long as law, tax and audit duties require
- Held against an anonymised profile — no longer a contactable person

Money-safe: deletion is blocked while you still hold a wallet balance, a pending withdrawal, funds in escrow, or an active booking — so no funds are stranded and no counterparty is left mid-deal. You resolve those first, then delete.

YOUR UK GDPR RIGHTS

Access • Rectification • Erasure • Portability • Object / restrict processing • Withdraw consent. Exercise any of them at support@whistleconnect.co.uk; you may also complain to the ICO (ico.org.uk).

Trust, Safety & Moderation

Because the platform carries user-to-user messaging, we operate a zero-tolerance approach to objectionable content and abusive behaviour, with tools for users and a queue for administrators.

Report Content

Any message or user can be reported from within a thread, sending it straight to the moderation queue.

Block Users

Blocking is mutual and enforced — blocked users cannot message each other, with under-16 safeguarding rules kept intact.

Admin Moderation Queue

Administrators review reports and can resolve, dismiss, or soft-remove an offending message from a dedicated dashboard.

Zero-Tolerance Policy

Our Terms of Service set an explicit zero-tolerance content clause; repeat or serious breaches lead to removal.

Removed messages are hidden from users but retained for audit, so moderation decisions can be reviewed. Reporting and blocking are always available — no configuration required.

[Report](#)[Block](#)[Admin review queue](#)[Audit-retained](#)

Platform Security & Operations

The application runs on managed, industry-standard infrastructure, with monitoring that lets us detect and respond to problems quickly.

Encrypted in Transit

All traffic is served over HTTPS with modern TLS. There is no unencrypted access to the app.

Managed Hosting

Hosted on Vercel's global edge network with a managed Supabase Postgres database and file storage.

Error Monitoring

Sentry captures errors and diagnostics (which may include IP and device data, as disclosed in our policy) so we can fix issues fast.

Secrets Management

API keys and signing secrets live in server-side configuration and are never committed to source code.

Essential Cookies Only

We use only the cookies needed to keep you signed in. No advertising trackers; we do not sell data.

International Transfers

Where a processor is outside the UK, transfers rely on UK adequacy or standard contractual clauses.

Operational safety nets — signature-verified webhooks, de-duplicated event handling and a weekly reconciliation job — mean issues are caught and corrected rather than silently accumulating.

Sub-Processors & Governance

We do not sell personal data. We share it only to run the service, meet legal and safeguarding duties, or with your consent. Our processors and partners are:

Partner	Purpose	Data involved
Supabase	Database, authentication & file storage	Core application & account data
Stripe	Payments, wallet, escrow & payouts	Payment & payout records (PCI DSS)
Sentry	Error monitoring & diagnostics	Diagnostics, may include IP address
Mapbox	Geocoding postcodes to approximate areas	Postcode
Resend	Transactional & verification emails	Name, email; FA number for verification
Vercel	Application hosting & delivery	Request & technical data
web-push / Firebase	Push notification delivery	Device push token only
The Football Association	Referee verification & safeguarding oversight	Referee name, FA number, county

Governance & Contact

Whistle Connect Ltd is the data controller. To exercise your rights, ask a question, or report a security concern, contact us — you may also complain to the UK ICO.

CONTACT
support@whistleconnect.co.uk
ico.org.uk

APPENDIX

The Detail

Technical controls & continuous hardening

The pages that follow are a technical appendix written for security reviewers. They can be shared — or withheld — separately from the overview above. Everything beyond this divider is candid, including items we are still hardening.

Technical Security Controls

A reviewer-oriented summary of the mechanisms behind the overview. Implementation detail is in the codebase and migration history.

Access control	Row-Level Security on application tables; admin gating via a server-side <i>is_admin()</i> check; per-user read/write policies.
Privileged functions	Money/booking logic runs in SECURITY DEFINER functions with a pinned search_path ; <i>anon</i> and <i>PUBLIC</i> EXECUTE are revoked (re-swept in a dedicated migration).
Authentication	Supabase Auth, password-based, with JWT sessions in cookies; profile creation uses bounded retry to avoid races.
Payment integrity	Idempotency keys on every Stripe write ; atomic 3-step withdrawal with an audit table; escrow hold/release via RPC; webhook events de-duplicated; separate account- and Connect-scope signing secrets .
Account deletion	<i>auth.uid()</i> -scoped RPC (no id argument to abuse); anonymise-not-delete; pre-checks block deletion while value/commitments remain; wallet ledger is immutable by trigger.
FA verification	Single-use token links; processed by the service role only; data-minimised to three fields (name, FA number, county).
Safeguarding	Under-16 lock set in the handle_new_user database trigger — not bypassable from application code; messaging block enforced server-side.
Transport & secrets	HTTPS/TLS throughout; secrets in server-side environment configuration; push (VAPID) keys are not committed to source control.

Continuous Hardening

We run automated Supabase security advisors and Sentry monitoring on an ongoing basis. The items below are **known, tracked and mitigated**, with planned hardening — shared here in the interest of transparency.

1 Direct execution of privileged database functions

OBSERVATION

Some privileged functions are callable by any signed-in user directly, not only through our server actions.

CURRENT MITIGATION

Row-Level Security still applies; money functions are idempotent and re-validate their inputs, so direct calls cannot bypass ownership or double-charge.

PLANNED HARDENING

Per-function `auth.uid()` guards / move non-helper functions to a private schema.

2 PostGIS in the public schema

OBSERVATION

The geospatial extension and its static spatial-reference lookup table live in the public schema.

CURRENT MITIGATION

The table holds only static reference data — no personal or sensitive information is exposed.

PLANNED HARDENING

Relocate PostGIS to a dedicated schema in a separately tested migration.

3 Leaked-password protection

OBSERVATION

The “have I been pwned” breached-password check is currently disabled.

CURRENT MITIGATION

Standard Supabase Auth protections and password requirements remain in force.

PLANNED HARDENING

Enable breached-password screening, or raise the minimum password length.

To report a security concern, contact support@whistleconnect.co.uk. We aim to acknowledge security reports promptly and keep reporters informed through to resolution.